

# Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (Weighted CVE + Exposure + Criticality) · Generated 2026-06-22 · SHA: `61ed8c3` · Model: `0.5·CVE_severity + 0.3·exposure + 0.2·business_criticality`

## Ranked Remediation Backlog

| # | Coordinate                                     | Version    | Band   | Risk | Top CVE                | Fix Version |
|---|------------------------------------------------|------------|--------|------|------------------------|-------------|
| 1 | org.apache.logging.log4j:log4j-core            | 2.14.1     | HIGH   | 7.8  | CVE-2021-44228 (10.0)  | 2.17.1      |
| 2 | com.fasterxml.jackson.core:jackson-databind    | 2.9.8      | HIGH   | 7.8  | CVE-2019-14379 (9.8)   | 2.14.0      |
| 3 | mysql:mysql-connector-java                     | 8.0.30     | HIGH   | 7.0  | CVE-2023-22102 (8.3)   | 8.0.31      |
| 4 | org.apache.logging.log4j:log4j-api             | 2.14.1     | HIGH   | 6.8  | CVE-2026-34479 (7.5)   | 2.24.3      |
| 5 | com.google.protobuf:protobuf-java              | 3.19.4     | HIGH   | 6.7  | CVE-2024-7254 (7.5)    | 3.25.5      |
| 6 | com.google.guava:guava                         | 24.1.1-jre | HIGH   | 6.3  | CVE-2023-2976 (7.1)    | 32.0.0-jre  |
| 7 | com.fasterxml.jackson.core:jackson-annotations | 2.9.0      | MEDIUM | 5.5  | CVE-2018-1000873 (6.5) | 2.9.8       |
| 8 | commons-io:commons-io                          | 2.4        | MEDIUM | 5.2  | CVE-2021-29425 (4.8)   | 2.22.0      |
| 9 | org.apache.commons:commons-lang3               | 3.4        | MEDIUM | 5.2  | CVE-2025-48924 (5.3)   | 3.20.0      |

**CRITICAL — Supply-chain (unscored).** `com.fastxml.jackson.core:jackson-databind:2.9.8` is a typosquatted coordinate that does not exist on Maven Central. It cannot be scored through the standard CVE pipeline but represents an immediate supply-chain risk. **Remove this dependency before any other action.**

**HIGH — Supply-chain (unscored).** Plain HTTP repository `http://insecure-mirror.example.net/maven2` is declared in `pom.xml`. This enables MITM artefact injection. **Remove the `internal-untrusted-mirror` repository block immediately.**

## Component Scores

| Dependency                  | CVE Severity | Exposure | Biz Criticality | Weighted Risk | Band   |
|-----------------------------|--------------|----------|-----------------|---------------|--------|
| log4j-core:2.14.1           | 10.0         | 8.0      | 2.0             | 7.8           | HIGH   |
| jackson-databind:2.9.8      | 10.0         | 8.0      | 2.0             | 7.8           | HIGH   |
| mysql-connector-java:8.0.30 | 8.3          | 8.0      | 2.0             | 7.0           | HIGH   |
| log4j-api:2.14.1            | 8.5          | 8.0      | 2.0             | 6.8           | HIGH   |
| protobuf-java:3.19.4        | 9.0          | 6.0      | 2.0             | 6.7           | HIGH   |
| guava:24.1.1-jre            | 7.6          | 7.0      | 2.0             | 6.3           | HIGH   |
| jackson-annotations:2.9.0   | 6.5          | 6.0      | 2.0             | 5.5           | MEDIUM |
| commons-io:2.4              | 5.3          | 7.0      | 2.0             | 5.2           | MEDIUM |

|                   |     |     |     |     |        |
|-------------------|-----|-----|-----|-----|--------|
| commons-lang3:3.4 | 5.3 | 7.0 | 2.0 | 5.2 | MEDIUM |
|-------------------|-----|-----|-----|-----|--------|

### Scoring Methodology

- **CVE Severity (weight 0.5):** maximum CVSS base score from scanner (NVD-sourced). Density bonus: +0.5 per additional CVE beyond the first, capped at 10.
- **Exposure (weight 0.3):** +4 direct / +2 transitive; +3 compile/runtime scope / +1 test scope; +1 network/serialization/parsing library. Cap 10.
- **Business Criticality (weight 0.2):** usage grep of source tree — `DiscountCalculator.java` imports `log4j-api / log4j-core` only; all other deps are not directly imported in production code (score 2, tagged `default`).
- **Floor rule:** any dependency carrying a CVSS  $\geq 9.0$  CVE is floored to band `HIGH` regardless of weighted score.

### Risk Band Summary

| Band                                                | Count |
|-----------------------------------------------------|-------|
| <b>CRITICAL</b> (score $\geq 8.0$ )                 | 0     |
| <b>HIGH</b> (score 6.0–7.9 OR CRITICAL CVE present) | 6     |
| <b>MEDIUM</b> (score 3.0–5.9)                       | 3     |
| <b>LOW</b> (score $< 3.0$ )                         | 0     |
| Supply-chain (unscored)                             | 2     |

### Priority Recommendations

1. **P0 — Immediate (supply-chain):** Remove `com.fastxml.jackson.core:jackson-databind` typosquatted dependency. Remove the `internal-untrusted-mirror` HTTP repository from `pom.xml`.
2. **P0 — Immediate (Log4Shell):** Upgrade `log4j-core` and `log4j-api` from `2.14.1` to `2.17.1` (minimum) or `2.24.3` (full remediation). CVE-2021-44228 is actively exploited in the wild with CVSS 10.0.
3. **P1 — This sprint (jackson-databind):** Upgrade `jackson-databind` from `2.9.8` to `2.14.0`. This dependency has 53 CVEs including 14 CRITICAL RCE gadget chains and is the single largest CVE surface in the project.
4. **P1 — This sprint (mysql-connector):** Upgrade `mysql-connector-java` from `8.0.30` to `8.0.33`. Resolves CVE-2023-22102 (CVSS 8.3) and brings `protobuf-java` to a safe version. Separately resolve the GPL v2 licence violation with your legal team.
5. **P2 — Next sprint (protobuf-java):** If `mysql-connector` upgrade does not pull a safe `protobuf-java` version, add an explicit `<dependencyManagement>` entry pinning `protobuf-java` to `3.25.5`.
6. **P2 — Next sprint (guava):** Upgrade `guava` from `24.1.1-jre` to `33.6.0-jre`. This is a major-version bump; review API changes before upgrading in a single PR.
7. **P3 — Backlog (minor deps):** Upgrade `commons-io` to `2.22.0`, `commons-lang3` to `3.20.0`. Resolves 3 MEDIUM CVEs with low blast radius.

Machine-readable source: `depscan-risk-report.json` (SHA `61ed8c3`). This report is ready for the **Auto-Remediation Skill** (Stage 3) and the **PR Validation Agent** (Stage 4).